HomeLab 4 (Security Governance, Risk, Compliance & Privacy (GRC))

STEP 1 — PICK ONE TOPIC

A. ACCESS CONTROL

Engineers share one AWS admin login. People who left months ago still have GitHub access. Nobody knows who approved what.

STEP 2 — SPLIT THE WORK (one role per person)

PERSON 1 — THE POLICY WRITER (Melita Jančenko)

DELIVERABLE: *A short Policy + Standard (half a page total).*

– Policy: 3-5 sentences. What's the rule? Why? Who does it apply to?

Access Control Policy

The company shall control access to systems, applications, and data based on business needs and job responsibilities. Access must be assigned to identifiable individuals and approved before use. Shared accounts are prohibited except where a documented technical exception is approved by management. This policy applies to all employees, contractors, and third parties who access company resources.

Rule: Access is approved, role-based, and tied to unique accounts; shared accounts are generally prohibited.

Why: To prevent unauthorized access and maintain accountability.

Who: Employees, contractors, and third parties.

– Standard: 4-6 specific, mandatory, TESTABLE requirements that support the policy.

Access Control Standard

Nr.	Requirement	Mandatory	Testable Requirement Supporting the Policy
1.	Every user must have a unique account; shared user accounts for administrative or normal business activities are prohibited.	Shall	Review user account lists and verify that accounts are assigned to individual users and that no shared accounts are in use.
2.	Access requests and access changes must be approved by the user's manager or system owner before access is granted.	Shall	Review access request records and verify documented approval from a manager or system owner before access was provided.
3.	Administrative privileges must be granted only to authorized personnel and must be documented.	Shall	Review privileged account lists and supporting documentation showing authorization and assignment.

4.	User access must be removed or disabled within one business day of employee or contractor termination.	Shall	Compare termination records with account deactivation dates to verify compliance.
5.	System owners must review user access at least quarterly and remove unnecessary access.	Shall	Compare termination records with account deactivation dates to verify compliance.
6.	Evidence of access approvals, modifications, reviews, and removals must be retained for a minimum of one year.	Shall	Review retained records and verify they are available and cover the previous 12 months.

Specific Requirement: What control or activity must be implemented.
Mandatory: The requirement is compulsory and uses the word "shall" to indicate obligation.
Testable Requirement Supporting the Policy: The evidence or verification method an auditor can use to confirm the requirement is being followed

PERSON 2 — THE RISK & PROCESS OWNER (Natalie Meintjes)

DELIVERABLE: *ONE risk register entry + ONE short procedure.*

Risk Register	
Risk ID	001
Title	Unauthorized access from shared and unmanaged accounts
Scenario (cause, event, effect)	**Cause**: user accounts are shared, access approvals are not documented and terminated users retain access. **Event**: Unauthorized individuals could gain or retain access to the company's systems. **Effect**: data is compromised, service is disrupted, accountability is lost.
Affected asset or process	AWS administration accounts, Github repositories and user access management
Likelihood	High
Impact	High
Risk owner	IT manager
Treatment (retain/ reduce/ share / avoid)	Reduce
Reason for treatment	If unique user accounts are created, approvals are documented, account removal is timely, and there are quarterly access reviews, the likelihood of unauthorized access will be greatly reduced while maintaining business operations.

Procedure:

Access request procedure:

1. The user submits an access request and identifies the system and access level required as well as a business related justification for the request.
2. The user's manager reviews the request and approves or rejects it.
3. The system owner then reviews the request and approves or rejects it.
4. The administrator verifies that the approvals are documented.

5. The administrator creates the user account, ensuring that it is unique, and assigns the access rights that have been approved.
6. The administrator records the access change and records the evidence of the approval in the access management records.
7. The user is notified once all approvals have been granted and they can begin using the system.

PERSON 3 — THE EVIDENCE & TICKET WRITER (Anna Ivanova)
DELIVERABLE: *Control-to-evidence map + ONE mock ticket.*

– Control-to-evidence map

Selected control: *"User access must be removed or disabled within one business day of employee or contractor termination."*

- Evidence 1: Records of termination from HR (HR keeps records of all employees or contractors who have left the company, including the exact date. This can serve as strong evidence - it gives a strong starting point for the “one-business-day” deadline countdown. Without this record, there is no way to find out if the deadline of access removal was met.
- Evidence 2: Account deactivations logs from AWS and GitHub (both AWS and GitHub automatically record a timestamp when an account is disabled or removed. This is strong evidence because it shows exactly when the action was taken, by whom, and on which account)
- Evidence 3: Access management records that are maintained by the admin (as described in part 2 of this Homelab - the administrator is required to record every access change. This log should name the person whose access was removed, the date of removal, and which systems were affected - very strong evidence, full scope of the action.)

– Mock ticket

* **Title:** Active account found for terminated employee
* **Severity:** High
* **Affected system:** Github (repos of the company)
* **What was observed:** During a quarterly access review, a GitHub account belonging to a developer who left the company 12 days ago was found to still be active. Account should have been disabled within one business day of termination
* **Next action:** disable account immediately; review access logs to check for any activity since the termination date; find out why the access removal was missed and adjust/update the offboarding process, so that this does not happen again.
* **Who to notify:** IT manager, HR, system owner.